COMPLIANCE

Data Protection Policy (UK GDPR)

What personal data is, how we handle it, and what to do with requests and breaches.

Version	Owner	Effective from	Next review	Applies to
2.3	Privacy Lead	1 Jun 2026	1 Jun 2027	All employees and contractors

1. What counts as personal data

Personal data is any information that identifies a living person, directly or indirectly: a name, email address, IP address, device ID, or a customer's end user mentioned inside a trace.

Special category data, such as health, ethnicity, religion or sexual orientation, needs extra protection. If you find it in a trace or a support ticket, do not copy it anywhere and tell the privacy team.

2. Our role

Data	Mubit's role	What that means
Customer traces and prompts	Processor	We act only on the customer's instructions, under their data processing agreement (DPA).
Employee and candidate data	Controller	We decide how it is used and must have a lawful basis for each use.
Website visitors and leads	Controller	Marketing use needs consent or legitimate interest, recorded in the CRM.

3. Principles for everyday work

- Use personal data only for the purpose it was collected for.
- Collect the minimum you need. Do not keep extra copies in spreadsheets, notes or Slack.
- Customer traces are kept for 90 days by default unless the customer's contract says otherwise.
- Personal data may only leave the UK or EU through systems approved by the privacy team.

4. Data subject requests

A data subject request is anyone asking to see, correct or delete their data, for example "what do you hold on me?" or "delete my account".

1. Do not reply to it yourself, even to say "we'll get back to you".
2. Forward it to privacy@mubit.example within 1 working day.
3. The privacy team responds. The legal deadline is one month from receipt.

5. Personal data breaches

A breach is any loss, leak or unauthorised access to personal data, including an email sent to the wrong person.

- Report it immediately in #security-incidents. Do not try to investigate or fix it alone.
- The privacy team decides whether the customer and the ICO must be told. Where required, the ICO must be notified within 72 hours.
- For customer traces, we tell the affected customer without undue delay, as our DPAs require.

6. Training

Complete data protection training within your first 14 days, alongside security training, and every year after that.